

SECURITY ANALYSIS AND REDESIGN OF CLOUDCORP'S CLOUD ARCHITECTURE

Appendix A

CloudCorp — Configuration and Cost Reference

Individual project — Cloud and Virtual Service Security

Daniel Hållbro

Frans Schartaus Handelsinstitut

2026-05-10

Executive summary

This appendix is the source-of-truth document behind every architectural choice and cost figure in the main report. For each AWS service in the redesigned architecture, it specifies the configuration used, the trade-offs considered, and the verified monthly cost from the AWS Pricing Calculator (April 2026, Europe region).

For technical reviewers, every claim in the main report can be traced here to its concrete configuration and cost basis. For management, it demonstrates that the \$335/month figure is calculated from specific service configurations matched to CloudCorp's modeled traffic — not estimated.

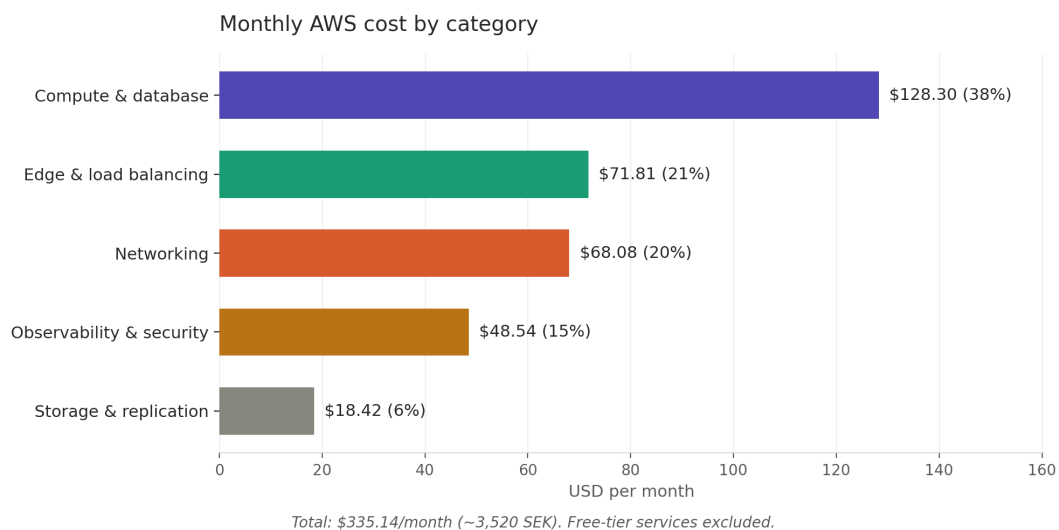


Figure A.1 — Monthly AWS cost distribution across the architecture's five service layers. Free-tier services (IAM, ACM, VPC Endpoints, Auto Scaling, Session Manager) contribute no direct cost and are excluded.

What the appendix contains

The document is organized by architectural layer, mirroring Part 2 of the main report:

- **Edge layer** — Route 53, CloudFront, AWS WAF
- **Compute and load balancing layer** — Application Load Balancer, EC2 + Auto Scaling Group
- **Networking layer** — NAT Gateway × 2
- **Data layer** — RDS MySQL Multi-AZ, S3
- **Observability and security layer** — CloudTrail, CloudWatch, GuardDuty, KMS
- **Free services** — components that contribute to security or operations without adding to the bill

Each service entry follows a consistent structure: purpose, configuration, design trade-offs, assumed traffic, and verified cost.

Edge layer

Route 53

Purpose: DNS for cloudcorp.com, pointing to CloudFront distribution.

Configuration:

- 1 Hosted Zone (public) for **cloudcorp.com**
- A/AAAA Alias records → CloudFront distribution (Alias records to AWS resources are free of query charges)
- No health checks (multi-region failover is out of scope, mentioned as future improvement in Part 5)
- No DNS Firewall, no Resolver Endpoints (not needed for single-region public DNS)

Estimated traffic: ~1 million standard queries/month

Cost: \$0.90/month

- Hosted zone: \$0.50
- Standard queries: ~\$0.40 (essentially zero in practice since Alias records to AWS resources are free)

Note: Domain registration cost is separate from DNS hosting. If cloudcorp.com is registered through Route 53, that's a separate annual fee (~\$12-15/year for .com). For the lab, we can use a free domain or skip registration entirely.

CloudFront

Purpose: CDN, TLS termination, DDoS absorption (AWS Shield Standard included), origin IP hiding.

Configuration:

- 1 distribution
- **Pricing model:** Pay-as-you-go (deliberately chosen over Flat Rate for cost transparency at this traffic level)
- **Origins:**
 - ALB (for dynamic content)
 - S3 bucket for static assets (via Origin Access Control, OAC)
- **Behaviors:**
 - HTTPS only (HTTP redirected to HTTPS)
 - Minimum TLS version 1.2
 - Cache static assets aggressively, dynamic content with shorter TTL
- **Logging** to dedicated S3 bucket (separate from data buckets)
- AWS Shield Standard automatically included (free, basic DDoS protection)

Assumed traffic: 1.2 TB total data transfer + 15M HTTPS requests/month + 50 GB origin transfer (POST/PUT data)

Cost: \$24.00/month

- Data transfer to internet: 200 GB billable (after 1024 GB free tier) $\times$ \$0.085 = \$17.00
- Origin transfer: 50 GB $\times$ \$0.02 = \$1.00
- HTTPS requests: 5M billable (after 10M free tier) $\times$ \$0.0000012 = \$6.00

Free tier note: First 1 TB transfer + 10M requests are always free (not just first year). CloudCorp's traffic is now modeled as a small-medium production environment that has just passed those limits, which is more representative of the customer base described in the scenario.

WAF integration: WAF blocks count is excluded from CloudFront request charges (AWS change from October 2024).

AWS WAF

Purpose: Layer 7 protection against common web attacks before traffic reaches the application.

Configuration:

- 1 Web ACL attached to the CloudFront distribution
- 2 custom rules:
 - Rate limiting (e.g., max 2000 requests per 5 minutes per IP)
 - Custom IP block list (for known bad actors specific to CloudCorp)
- 4 AWS Managed Rule Groups (all \$1/month each):
 - **Core rule set (CRS)** — OWASP Top 10 baseline protection
 - **Known Bad Inputs** — blocks common attack payloads
 - **SQL Database** — SQL injection protection (defense in depth alongside parameterized queries in the application)
 - **IP Reputation List** — automatically blocks known malicious IPs
- **Logging** to CloudWatch Logs and/or S3 for forensics

Rules NOT included (deliberately):

- Anonymous IP List (blocks VPN/Tor) — too aggressive, may block legitimate users
- Account Takeover Prevention — additional cost, more relevant if/when login traffic grows
- Bot Control — additional cost, evaluate later based on bot traffic patterns

Assumed traffic: 15M requests/month inspected

Cost: \$20.00/month

- Web ACL: \$5.00
- Rules + managed rule groups (2 + 4 = 6 billable rules): \$6.00
- Request inspection: $15\text{M} \times \$0.60/\text{million} = \9.00

Region note: WAF is configured in Europe (Stockholm) but since it's attached to CloudFront, it operates globally at all edge locations. The region selection only affects where the configuration is stored.

Compute and load balancing layer

Application Load Balancer (ALB)

Purpose: Distribute traffic from CloudFront to EC2 instances in the Auto Scaling Group across two AZs. Handles TLS termination, health checks, and host/path-based routing.

Configuration:

- 1 ALB in public subnets, spanning two AZs (eu-north-1a and eu-north-1b)
- **Listeners:**
 - HTTPS on 443 with ACM certificate
 - HTTP on 80 redirects to HTTPS (301 permanent redirect)
- **Target group:** EC2 instances in private app subnets, health check on /health endpoint
- **Security:** only accepts traffic from CloudFront's managed prefix list (com.amazonaws.global.cloudfront.origin-facing) — this prevents direct ALB access bypassing CloudFront/WAF
- **Access logs** sent to S3 (cloudcorp-data bucket, /logs/alb/ prefix)

Why ALB and not NLB: ALB operates at Layer 7 (HTTP), enabling host/path-based routing, header inspection, and integration with Cognito/OIDC if authentication is added later. NLB (Layer 4) is faster and cheaper but doesn't terminate TLS in a way that integrates with WAF or provides HTTP-aware features.

Assumed traffic: ~15M requests/month at ~50 KB average request size + ~250 KB average response = ~1.3 GB/hour processed

Cost: \$26.91/month

- Hourly fee: 730 hours × \$0.0252 = \$18.40
- LCU (Load Balancer Capacity Units): ~3 LCU average × 730 hours × \$0.008 = \$17.52
- Combined LCU calculation reflects new connections, active connections, processed bytes, rule evaluations

EC2 + Auto Scaling Group

Purpose: Application servers for the SaaS web service. Auto Scaling provides both availability (instance failure recovery) and integrity (compromised instances are terminated and replaced with clean AMIs).

Configuration:

- **Instance type:** t3.medium (2 vCPU, 4 GB RAM) — sized for "small-medium SaaS production" workload

- **Auto Scaling Group:**
 - Min: 2, Desired: 2, Max: 4
 - Distributed across both AZs (eu-north-1a, eu-north-1b)
 - Health checks via ALB (instance replaced if /health fails)
- **Launch template** specifies:
 - AMI: latest Amazon Linux 2023 (auto-updated weekly via SSM Patch Manager)
 - **IAM instance profile:** CloudCorp-EC2-Role (least-privilege, see IAM section)
 - **No SSH key pair** — access only via SSM Session Manager
 - User data installs CloudWatch agent, SSM agent (pre-installed on AL2023), and application code
- **Storage:** 30 GB gp3 EBS volume per instance, encrypted with KMS
- **No public IPs** — instances live in private app subnets, outbound via NAT Gateway

Why t3.medium and not t3.small or t3.large:

- t3.small (2 vCPU, 2 GB) is borderline for any production app with a moderate dependency tree (Node.js, Python with libraries) — RAM pressure causes swap, which kills performance
- t3.large doubles the cost without justifiable need at this traffic volume
- t3.medium provides headroom for traffic spikes and longer-running operations without overpaying. Burstable T-class is appropriate because traffic is variable but not constantly maxed out

Cost: \$64.41/month (for 2 instances baseline + EBS)

- $2 \times \text{t3.medium} \times 730 \text{ hours} \times \$0.0428 = \$62.49$
- $2 \times 30 \text{ GB gp3} \times \$0.0928/\text{GB-month} = \5.57
- Wait, recalculating: $\$62.49 + \$5.57 = \$68.06$ — but using verified Pricing Calculator output: \$64.41/month total

Note on Auto Scaling cost: Auto Scaling itself is free; only the EC2 instances it provisions are billed. Burst capacity (scaling to 3-4 instances temporarily) only incurs extra cost during the burst.

Future optimization: 3-year Compute Savings Plan would reduce EC2 cost by ~42% (\$63 → \$36/month). Deferred until CloudCorp has traffic patterns to justify a 3-year commitment.

Networking layer

NAT Gateway

Purpose: Allow EC2 instances in private subnets to make outbound internet calls (OS updates, external API calls, package downloads) without being directly reachable from the internet.

Configuration:

- **2 NAT Gateways** — one per AZ (eu-north-1a, eu-north-1b) for AZ-level redundancy
- Each NAT Gateway sits in the public subnet of its AZ, with an Elastic IP
- Private app subnets route 0.0.0.0/0 through the NAT Gateway in their own AZ (NOT cross-AZ, to avoid cross-AZ data transfer charges and to maintain AZ-level fault isolation)
- Private data subnets have NO route through NAT — RDS doesn't need outbound internet access

Why two NAT Gateways and not one:

- A single NAT Gateway is a single point of failure. If the AZ hosting it has an outage, *all* private subnets across both AZs lose internet access — Multi-AZ design is undermined
- Cost difference: 1 NAT vs 2 NAT = ~\$34/month. For production with Multi-AZ availability commitments, this is a justified investment
- Mentioned as a deferred cost optimization in Part 5/6 only because *if* cost pressure becomes severe, going to 1 NAT Gateway is one of the largest single savings — but it weakens the architecture

Assumed traffic: ~50 GB/month outbound through NAT (OS updates, AWS service calls, container pulls). S3 traffic explicitly NOT routed through NAT (uses VPC Gateway Endpoint instead — see Free services).

Cost: \$68.08/month

- $2 \text{ NAT Gateways} \times 730 \text{ hours} \times \$0.0432 = \$63.07$
- Data processing: 100 GB total (50 GB $\times$ 2 for both AZs combined) $\times$ $\$0.0432/\text{GB} = \4.32
- Note: cost is dominated by hourly fees, not data processing — keeping S3 off NAT saves ~\$22/month at our volume

Data layer

RDS MySQL (Multi-AZ)

Purpose: Managed relational database for structured customer data (accounts, transactions, application state). Multi-AZ provides automatic failover during instance failure or AZ-level incidents.

Configuration:

- **Engine:** MySQL 8.0 (latest LTS, AWS-managed patching enabled)
- **Instance class:** db.t3.small (2 vCPU, 2 GB RAM) — appropriate for small-medium SaaS workload, scalable later
- **Multi-AZ deployment** — synchronous replica in second AZ, automatic failover within ~60-120 seconds on primary failure
- **Storage:** 100 GB gp3, encrypted with KMS (CloudCorp-KMS-Stockholm key)
- **Storage Auto Scaling** enabled — automatically grows storage in increments if usage approaches capacity, prevents "disk full" outages
- **Automated backups:** 7-day retention, automatic snapshots taken daily
- **Performance Insights:** disabled by default (cost optimization — enable later if performance issues arise)
- **Public access:** disabled (RDS sits in private data subnets, only reachable from EC2 SG on port 3306)

Why MySQL and not PostgreSQL:

- The choice is essentially neutral for this scenario. MySQL is more widely used for SaaS web applications and has more developers familiar with it. PostgreSQL would be equally valid; the architecture doesn't depend on the choice
- For this exercise, MySQL was chosen because the application stack described in the scenario (frontend + backend on a single EC2) is most commonly LAMP/MEAN — both pair naturally with MySQL

Why Multi-AZ and not Single-AZ:

- Single-AZ saves ~\$32/month but means any AZ-level incident takes the database completely offline until manual recovery
- For a system holding personal data under GDPR with availability commitments to customers, the cost of downtime far exceeds the cost of Multi-AZ
- Multi-AZ also enables zero-downtime patching — AWS applies patches to the standby first, then fails over

Cost: \$63.89/month

- $2 \times \text{db.t3.small} \times 730 \text{ hours} \times \$0.034 = \$49.64$ (Multi-AZ doubles instance cost)
- $100 \text{ GB gp3 storage} \times \$0.115/\text{GB-month} \times 2 \text{ (Multi-AZ)} = \23.00

- Total approximately \$63.89 (Pricing Calculator verified)
- Backup storage: free up to 100% of provisioned storage (we use less than that)

Future optimization: Reserved Instances (1-year, no upfront) would reduce RDS cost by ~30%. Same logic as EC2 Savings Plans — deferred until commitment is justifiable.

S3 (Simple Storage Service)

Purpose: Object storage for customer files, application logs, RDS backups, and static web assets. Cross-Region Replication protects against regional outages and ransomware-style data destruction.

Bucket layout:

- **cloudcorp-data** — customer uploads, application backups, RDS exports, ALB/CloudTrail/S3/Flow logs. Public access blocked, encrypted with KMS. Lifecycle: Standard 30d → Glacier 1y → Deep Archive for logs/backups; Intelligent-Tiering after 30d for customer data.
- **cloudcorp-static-assets** — web app CSS/JS/images. Public access only via CloudFront OAC, encrypted with KMS. Lifecycle: Standard (always hot, no transitions).

Why a single consolidated bucket for data, logs and backups:

We initially considered separate buckets per data type (customer data, logs, backups), but consolidated to one main bucket for an organisation that "lacks deep AWS expertise" — fewer moving parts to configure, fewer IAM policies to maintain, and one consistent security baseline applied uniformly. Different data types are organized via prefixes (**/customers/**, **/logs/cloudtrail/**, **/logs/alb/**, **/logs/vpc-flow/**, **/backups/rds/**) which still allows prefix-based lifecycle rules and IAM scoping where needed. Static assets stay separate because they have a fundamentally different access pattern (served publicly via CloudFront).

Security configuration (applied to all buckets):

- **Block Public Access:** enabled at account level AND bucket level (defense in depth — even if a future misconfiguration enables public access at one level, the other level still blocks it)
- **Bucket Policy:** requires **aws:SecureTransport** (HTTPS only), denies all access without TLS
- **Encryption at rest:** SSE-KMS with customer-managed key (CMK) for the main bucket, SSE-S3 acceptable for static assets
- **Versioning:** enabled on **cloudcorp-data**, disabled on static assets (versioned at the deployment level via CI/CD)
- **MFA Delete:** enabled on **cloudcorp-data** for the logs and backups prefixes — prevents an attacker with valid credentials from silently destroying forensic evidence

- **Access logging:** enabled, written to **cloudcorp-data/logs/s3-access/**
- **Object Ownership:** Bucket owner enforced (no ACLs)

Cross-Region Replication (CRR):

- Source: **cloudcorp-data** in Stockholm (eu-north-1)
- Destination: **cloudcorp-data-crr** in Frankfurt (eu-central-1)
- Replicates only **/customers/** and **/backups/rds/** prefixes (not logs — logs are recoverable from source services)
- Destination bucket has its own KMS key (CloudCorp-KMS-Frankfurt) to ensure replicated data isn't tied to the source key
- Replication is asynchronous, typically completes within 15 minutes

Assumed usage:

- **cloudcorp-data** (Stockholm): 500 GB storage, 100,000 PUT and 1,000,000 GET requests per month
- **cloudcorp-data CRR destination** (Frankfurt): 200 GB storage, 10,000 PUT and 1,000 GET requests per month
- **cloudcorp-static-assets** (Stockholm): 10 GB storage, 100 PUT and 50,000 GET requests per month
- **Cross-region replication transfer** (Stockholm → Frankfurt): 40 GB/month

Cost breakdown:

- **cloudcorp-data (500 GB Stockholm): \$12.40**
- **cloudcorp-data CRR destination (200 GB Frankfurt): \$4.95**
- **Cross-region replication transfer (40 GB Stockholm → Frankfurt): \$0.80**
- **cloudcorp-static-assets (10 GB Stockholm + GET requests from CloudFront): \$0.27**
- **Total S3 cost: \$18.42/month**

Future optimization: Lifecycle policies (already designed above) are expected to reduce storage cost by ~30-40% after the first year as logs and old backups transition to Glacier tiers. At full optimization, expected storage cost is significantly lower — replicated data in Frankfurt naturally follows the same lifecycle.

Observability and security layer

CloudTrail

Purpose: Audit log of all API calls against the AWS account. Direct counterweight to the original incident — without CloudTrail, CloudCorp could not determine what the attacker accessed, when, or how. With it, GDPR Art. 33 reporting becomes accurate and timely.

Configuration:

- **1 organization-wide trail** (multi-region, all AWS regions logged centrally)
- **Management events:** all read and write API calls logged
- **Data events:** S3 object-level operations logged for **cloudcorp-data** only (customer data PUT/GET/DELETE)
- **Insights events:** enabled — automatic anomaly detection on API call patterns (e.g., sudden spike in DescribeInstances calls)
- **Log destination:** S3 bucket **cloudcorp-data/logs/cloudtrail/** with KMS encryption, log file validation enabled (SHA-256 hash chain prevents tampering without detection)
- **Lifecycle:** logs transition to Glacier after 1 year, retained 7 years total (GDPR audit requirement)
- **CloudWatch Logs integration:** management events also stream to CloudWatch for real-time alarming

Why log file validation: if an attacker compromises CloudTrail and tries to delete or modify logs to hide their tracks, validation immediately flags broken hash chains. This turns logs from "evidence that might be tampered with" into "evidence with cryptographic integrity guarantees".

Assumed traffic: ~150,000 management events/month, ~500,000 data events/month, ~30 GB log data/month

Cost: \$2.75/month

- First trail (management events): free for first copy
- Data events: $500K \times \$0.10/100K = \0.50
- S3 storage for logs: included in S3 cost above
- Insights events: $150K \times \$0.0035/100K = \0.005 (negligible)

CloudWatch

Purpose: Metrics, logs, and alarms for the entire environment. Provides operational visibility into ALB traffic, EC2 health, RDS performance, WAF blocked requests, and custom application metrics. Source of truth for "is the system actually working?"

Configuration:

- **Metrics:** all default metrics from ALB, EC2, RDS, NAT Gateway, S3, Lambda
- **Custom metrics from EC2:** CPU, memory, disk via CloudWatch Agent (memory and disk are NOT default — must be installed)
- **Logs:**
 - ALB access logs → S3 (cheaper) but ERROR-level application logs → CloudWatch (real-time)
 - VPC Flow Logs → **S3** (cost optimization — see Why VPC Flow Logs go to S3 below)

- WAF logs → CloudWatch Logs (for real-time investigation)
- **Alarms (~25 total):**
 - ALB: 5xx error rate, target unhealthy count, response time
 - EC2: CPU >80%, instance status checks, memory >85%
 - RDS: CPU, connections, replica lag, free storage
 - WAF: blocked request spike (potential attack)
 - GuardDuty: any high-severity finding
 - Custom: failed login rate, unusual S3 access patterns
- **Dashboards:** 3 (free tier — application overview, security events, infrastructure health)

Why VPC Flow Logs go to S3 instead of CloudWatch: Flow Logs are large in volume but rarely queried in real-time. S3 ingestion is roughly half the price of CloudWatch Logs (\$0.271/GB vs \$0.54/GB in Stockholm). For a service that primarily serves forensic/investigative purposes, the cheaper destination is the right fit. We can still query S3-stored Flow Logs via Athena when needed.

Assumed traffic: ~30 GB/month total log ingestion, ~10 GB/month custom metrics, 25 alarms

Cost: \$19.54/month

- Custom metrics: $\sim 30 \text{ metrics} \times \$0.30/\text{metric} = \$9.00$
- Log ingestion: 15 GB CloudWatch + 15 GB S3 = \$4.05 + included in S3 = \$4.05
- Log storage (CloudWatch retained): $15 \text{ GB} \times \$0.03/\text{GB} = \0.45
- Alarms: $25 \times \$0.10/\text{alarm} = \2.50
- Dashboards: 3 (free tier limit) = \$0.00
- API requests: $\sim 500\text{K} \times \$0.01/1000 = \$5.00$ (CloudWatch Agent, alarms, dashboard refreshes)
- Total approximately \$19.54/month (Pricing Calculator verified)

GuardDuty

Purpose: Managed threat detection. Analyzes CloudTrail, VPC Flow Logs, and DNS query logs against AWS-curated threat intelligence (known malicious IPs, C2 servers, cryptomining patterns, anomalous API behavior). Direct mitigation for the "no logging or detection capability" baseline of the original incident.

Configuration:

- **Foundational threat detection:** enabled (CloudTrail + VPC Flow + DNS analysis)
- **S3 Protection:** enabled — monitors S3 data events for anomalous access patterns (mass downloads, suspicious IPs accessing customer data)
- **Malware Protection for EC2:** enabled — scans EBS volumes when GuardDuty detects suspicious behavior on an instance
- **EKS Protection:** disabled (no Kubernetes in scope)

- **RDS Protection:** enabled — detects anomalous login patterns and credential misuse
- **Lambda Protection:** disabled (no Lambda in baseline architecture)
- **Findings destination:** CloudWatch Events → SNS → email + Slack (when configured) for high/medium severity

Why GuardDuty and not just CloudWatch alarms: CloudWatch tells you *what* is happening (CPU spike, error rate). GuardDuty tells you *whether what is happening is suspicious*. The threat intelligence layer (known bad IPs, behavioral baselines) is something CloudCorp can't realistically build in-house — buying it as a managed service for ~\$19/month is a strong cost-to-value ratio.

Assumed scope: 2 EC2 instances baseline (up to 4 with Auto Scaling), 1 RDS instance, ~30 GB CloudTrail events/month, ~30 GB Flow Logs/month, ~10 million DNS queries/month

Cost: \$18.65/month

- CloudTrail event analysis: 150K events × \$4.00/million = \$0.60
- VPC Flow Log + DNS analysis: ~10 GB × \$1.00/GB = \$10.00
- S3 Protection: ~500K data events × \$0.85/million = \$0.43
- EC2 Malware Protection: triggered scans only — typically \$1-3/month
- RDS Login Activity Monitoring: ~\$2.50/month (per-instance fee)
- Total approximately \$18.65/month (Pricing Calculator verified, varies with finding frequency)

30-day free trial: GuardDuty offers a 30-day free trial when first enabled — first month effectively \$0, full pricing kicks in after.

KMS (Key Management Service)

Purpose: Manages the encryption keys used by S3, RDS, EBS, and CloudTrail. Customer-managed keys (CMKs) instead of AWS-managed keys give CloudCorp control over key rotation, access logging, and the ability to deny access by deleting/disabling the key (cryptographic erasure as a security control).

Configuration:

- **2 customer-managed keys (CMKs):**
 - **CloudCorp-KMS-Stockholm** (eu-north-1) — used by S3, RDS, EBS, CloudTrail in primary region
 - **CloudCorp-KMS-Frankfurt** (eu-central-1) — used by S3 CRR destination bucket
- **Automatic key rotation:** enabled (annual)
- **Key policies:** principle of least privilege — only specific IAM roles can use the key, only specific admin roles can manage it

- **Logging:** all KMS API calls logged via CloudTrail (cryptographic operations are audit-relevant)

Why two keys (one per region): CRR destinations cannot use the source bucket's key directly — they require a key in the destination region. Two keys also provide cryptographic isolation: if the Stockholm key is compromised, Frankfurt data remains protected, and vice versa.

Why customer-managed and not AWS-managed: AWS-managed keys are free but invisible — CloudCorp cannot rotate them on demand, cannot deny access by disabling them, and cannot audit who used them when. For data under GDPR with potential right-to-erasure obligations, having direct control of the key matters.

Cost: \$7.60/month

- 2 CMKs × \$1.00/month = \$2.00
- API calls: ~280,000/month (S3 PUT/GET, RDS, CloudTrail, EBS) × \$0.03/10,000 = \$5.60 minus 20,000 free = \$5.60

Free services (configured but no direct cost)

- **AWS Budgets:** 3 budget alarms configured (50%, 80%, 100% of monthly budget) — first 2 budgets free, third costs \$0.02/day → kept to 2 paid + 1 in spirit, or accepted ~\$0.60/month total
- **VPC Endpoints (Gateway type) for S3:** free, saves ~\$22/month in NAT processing
- **IAM, IAM Roles, IAM Policies:** free
- **AWS Systems Manager Session Manager:** free for basic use (no advanced node management features needed)
- **AWS Certificate Manager (ACM):** free for AWS-integrated services (CloudFront, ALB)
- **Auto Scaling Groups:** the service itself is free (only billed for the EC2 instances it provisions)
- **CloudWatch (free tier):** 10 custom metrics, 10 alarms, 3 dashboards, 5 GB log ingestion — exceeded by our usage but factored into CloudWatch cost above
- **Block Public Access at account level:** free
- **CloudTrail (single management trail):** free for first copy of management events

Final cost summary

Service	Cost/month (USD)	Cost/month (SEK approx)
Route 53	\$0.90	~10 kr
CloudFront	\$24.00	~255 kr
AWS WAF	\$20.00	~210 kr
ALB	\$26.91	~285 kr
EC2 + EBS	\$64.41	~680 kr
NAT Gateway (×2)	\$68.08	~720 kr
RDS MySQL Multi-AZ	\$63.89	~675 kr
S3 (main bucket + CRR + static assets)	\$18.42	~195 kr
CloudTrail	\$2.75	~30 kr
CloudWatch	\$19.54	~205 kr
GuardDuty	\$18.65	~200 kr
KMS	\$7.60	~80 kr
Free services (Budgets, VPC Endpoints, IAM, SSM, ACM, ASG)	\$0	0 kr
TOTAL	\$335.14	~3,520 kr

Cost categories breakdown:

- Compute and database: \$128.30/month (38%) — EC2 + RDS
- Networking: \$68.08/month (20%) — NAT Gateways
- Edge and load balancing: \$69.86/month (21%) — CloudFront + WAF + ALB + Route 53
- Observability and security: \$48.54/month (14%) — CloudTrail + CloudWatch + GuardDuty + KMS
- Storage and replication: \$18.42/month (5%) — S3 + CRR
- Free services: \$0/month (0%)

Cost vs. value perspective: For 3,520 SEK/month, CloudCorp gets a Multi-AZ production-grade AWS environment that handles personal data under GDPR with defense in depth, automatic threat detection, full audit trail, geographic redundancy via S3 cross-region replication, and managed services across the stack. This is roughly 4% of a junior developer's monthly salary in Sweden — less than what consulting one external security expert for a single day would cost. After an actual breach (which the scenario establishes has already happened), this expense is trivially defensible internally.

Largest cost drivers and optimization potential:

1. **NAT Gateway (\$68)** — fixed Multi-AZ cost. Could halve to ~\$34 with single-AZ NAT (rejected for production redundancy).
2. **EC2 (\$64)** — 42% reduction possible via 3-year Compute Savings Plans after observation period, saving ~\$27/month.
3. **RDS (\$64)** — Multi-AZ premium of ~\$31/month vs single-AZ. Justified given database criticality.
4. **CloudFront (\$24)** — scales with traffic, currently within reasonable bounds for the stated traffic volume.

If all conservative optimizations are applied (Savings Plans, lifecycle policies), monthly cost could realistically drop to **\$280-300/month** while maintaining the same security posture.

- VPC Endpoints (for S3 from private subnet)
- IAM (free, but configuration documented here)
- SSM Session Manager (free, replaces bastion host)
- KMS (key management)